

BÁO CÁO CHUYÊN ĐỀ

Kiến trúc SEC đã thực thi trên EGAL / Gia Phả Số

Security Doctrine v1.1 · Implementation Guide v1.1 (bổ sung Turnstile placement)

Phiên bản tài liệu: 1.1.0

Ngày: 2026-07-28

Thay đổi v1.1: Làm rõ lớp Turnstile (as-is vs hướng đích); thêm mục delayed task tách middleware.

Phạm vi code: Backend Wave 0–5 (Master Implementation Plan v1.2)

SSOT: EGAL-SEC Security Doctrine v1.1 · CED v1.1 · OPD v1.2 · Master Plan v1.2

Repo: github.com/QuangAGS/cmcodes · Docs: github.com/QuangAGS/CM-Docs

1. Mục đích & đối tượng đọc

Tài liệu mô tả kiến trúc an ninh (SEC) đã được hiện thực trên backend EGAL — không chỉ liệt kê file, mà giải thích vì sao từng lớp tồn tại, thứ tự bắt buộc trên pipeline, hợp đồng lỗi, và quy tắc khi mở rộng feature mới.

- Đội hệ thống / DevOps: boundary, worker, env cấm production, correlationId / BPL.
- Đội lập trình: gắn middleware đúng chỗ, không bypass gate, ném lỗi CED.
- Reviewer: đối chiếu SEC Doctrine v1.1 với code W0–W5.

2. Nguyên tắc cốt lõi SEC đã khóa trong code

2.1 Defense-in-Depth

Nhiều lớp độc lập; lớp sau không giả định lớp trước đã đủ. Mỗi request đi pipeline cố định.

2.2 Human-friendly security

Rate limit và thông báo tiếng Việt; Turnstile bắt buộc production qua config, không hardcode bypass trên main.

2.3 Traceability (CED × SEC)

Lỗi operational và log an ninh mang correlationId; notif PENDING và BPL giữ correlation_id (HTTP → worker).

2.4 Least privilege + tenant isolation

CLAN_ADMIN trong tenant; SYSTEM_ADMIN bypass check status nhưng vẫn resolve context. Role đúng nhưng user/tenant chưa kích hoạt → Heavy gate chặn API quản trị.

2.5 Fail closed trên cổng nhảy

Thiếu token, CAPTCHA fail, tenant chưa kích hoạt trên API duyệt, account lock → từ chối rõ mã.

3. Sơ đồ pipeline request (HTTP)

Thứ tự chuẩn (không được đảo khi thêm route mới):

correlation → rateLimit → securityGuard? → turnstileGate* → verifyToken → checkRole → tenantStatus → handler → CED global handler

* turnstileGate: lớp logic bắt buộc trên form public bot-risk. As-is: orchestration trong auth.controller gọi turnstile.utils. Hướng đích (delayed): turnstile.middleware — xem mục 14.

Lớp	Module / file (as-is)	Trách nhiệm SEC
1. Correlation	correlation.middleware	X-Correlation-Id; req.correlationId
2. Rate limit	rateLimit.middleware	login/register/onboarding/check-identity; IP key normalize
3. SecurityGuard	securityGuard.middleware	restrictSuspiciousActivity admin paths
4. Turnstile (bot gate)	As-is: auth.controller + turnstile.utils — Đích: turnstile.middleware (P2/P3)	TURNSTILE_REQUIRED + siteverify; cấm TEMP bypass; action login register ...
5. IP / honeypot	ipBlock + controller hp_field	blockIP sau honeypot / suspicious
6. verifyToken	auth.middleware	JWT; dual req.user; INVALID_TOKEN

7. checkRole	role.middleware	RBAC + user DA_DUYET trên admin
8. tenantStatus	tenantStatus.middleware	Light/Heavy; SYS_ADMIN bypass check, giữ context
9. Handler	controller + service	Assert order; business; notif PENDING in TX
10. Global CED	createGlobalErrorHandler({legacy:true})	Dual-contract + correlationId

3.1 Ghi chú kiến trúc lớp Turnstile

- Cột “Module / file” mô tả implementation hiện tại, không phải điều cấm Doctrine.
- SEC Doctrine yêu cầu: verify server-side, cấu hình TURNSTILE_REQUIRED, không TEMP bypass — không khóa phải nằm trong auth.controller.
- I/O Cloudflare đã tách turnstile.utils; controller chỉ orchestrate. Tách middleware là refactor sáng pipeline (mục 14).

3.2 Ma trận gắn lớp theo nhóm route

Nhóm route	Lớp SEC tối thiểu
Public login/register/reset	correlation + rateLimit + Turnstile gate + honeypot + IP (không verifyToken)
Auth /me	correlation + verifyToken
Admin approve / query-reviewable	verifyToken + checkRole + Heavy + securityGuard
Onboarding user write	onboardingWriteRateLimiter + verifyToken
Onboarding admin	admin rate + verifyToken + checkRole + Heavy + securityGuard
POST /clan/activate	write rate + verifyToken — whitelist không Heavy
Members list	verifyToken; filter CHINH_THUC mặc định

4. Lớp xác thực & phiên (Authentication)

4.1 JWT verifyToken

- auth.middleware.js — thiếu token UNAUTHORIZED; hết hạn/sai INVALID_TOKEN.
- Dual fields req.user (Q1). Không thay tenantStatus gate.

4.2 Login Assert Order

- 1) Credential → 401 + attempt
- 2) Lockout locked_until / max attempts → 423
- 3) User lifecycle CHO_DUYET / disabled
- 4) Tenant lifecycle (login TAM_NGUNG cho CLAN_ADMIN hoàn thiện; Heavy chặn duyệt)

Không đảo thứ tự để tránh enumeration thô.

4.3 Turnstile & Honeypot (as-is)

- securityConfig.TURNSTILE_REQUIRED (default true) + SECRET_KEY.
- As-is: auth.controller gọi validateTurnstile(token, ip, action) từ turnstile.utils sau khi check hp_field / thiếu token.
- Áp dụng login, register, forgot-password, verify-reset-code.
- Cấm TEMP { success: true } trên main; dev chỉ TURNSTILE_REQUIRED=false.
- Hướng đích kiến trúc: turnstile.middleware(action) trên route — không đưa vào auth.service (domain). Chi tiết & điều kiện kích hoạt: mục 14.

4.4 Rate limit

- validate:false (v7); normalize ::1 → 127.0.0.1; 429 + correlationId khi có.

5. Phân quyền & cổng tenant

5.1 checkRole

- RBAC + status DA_DUYET trên path admin (chống leo thang CHO_DUYET).

5.2 tenantStatus Light / Heavy

- Heavy: TAM_NGUNG / CHO_DUYET / BI_KHOA → TENANT_NOT_ACTIVATED...; next(createError) + correlationId.
- SYSTEM_ADMIN bypass check status, vẫn gán context nếu có.
- requireActiveTenant = alias Heavy (Q1).

5.3 Whitelist /clan/activate

Không Heavy — CLAN_ADMIN + TAM_NGUNG được kích hoạt dòng họ.

5.4 Members visibility

- Mặc định CHINH_THUC; override status=DU_BI|ALL; enum chỉ DU_BI|CHINH_THUC.

6. Ủy quyền on_behalf_of (SEC D — W5)

- buildActorContext: actor ≠ subject; cấm ghi đè req.user.userId.
- BPL DELEGATED_ACTION; job JOB_RUNNER.

Residual: wire đủ processApproval.

7. Nhật ký an ninh & BPL

- auth_logs / attempt + failure_reason TURNSTILE_*, HONEYPOT_*, LOGIN_REJECTED_*.
- BPL: correlation_id, process_type, actor_type, metadata action constants.
- ONBOARDING_EXPIRED / USER_TEMP_UNLOCKED / DELEGATED_ACTION.

8. Thông báo PENDING (outbox-lite)

- INSERT PENDING trong TX nghiệp vụ; worker FOR UPDATE SKIP LOCKED.
- Reclaim SENDING > 10p; max attempts 3 → FAILED; log correlation_id.

Schedule: node src/jobs/runNotificationWorker.js — cấm FORCE_FAIL production.

9. Jobs lifecycle

- onboardingExpire: whitelist + updated_at 30d; atomic EXPIRED + notif + BPL.
- tempUnlock: locked_until past; skip BI_CAM; BPL USER_TEMP_UNLOCKED.

Không chạy job nặng trong HTTP process.

10. Hợp đồng lỗi an ninh

```
{ success:false, error:{ code, message, correlationId }, code, message [, legacyCode ] }
```

Code	HTTP	Khi nào
UNAUTHORIZED	401	Thiếu token
INVALID_TOKEN	403	JWT hết hạn/sai
ACCOUNT_LOCKED / ACCOUNT_CHO_DUYET	423	Lock / chờ duyệt
TENANT_NOT_ACTIVATED	403	Heavy gate
LOGIN_RATE_LIMITED / ...	429	Rate window
TURNSTILE_REQUIRED / FAILED	403	CAPTCHA

11. Checklist khi thêm API mới

- 1. correlation không bị xóa.
- 2. Public nhập → rateLimit (+ Turnstile gate nếu bot-risk).
- 3. Auth → verifyToken; admin → checkRole + Heavy (trừ whitelist văn bản).
- 4. on_behalf_of → actorContext + BPL.
- 5. Critical side-effect → notif PENDING trong TX.
- 6. createError/BusinessError — codes shared/errors.
- 7. Không TEMP Turnstile; không claim PENDING thiếu SKIP LOCKED.

- 8. Job: LIMIT batch.
- 9. Smoke 401/403/429 + correlationId.
- 10. Review route có đủ lớp pipeline mục 3.

12. Biên giới FE / BE

- BE enforce mọi rule; FE chỉ UX (widget Turnstile, clear token khi INVALID_TOKEN, không spam approve khi TENANT_NOT_ACTIVATED).

13. Cấu hình & env an toàn

- TURNSTILE_REQUIRED=true production; SECRET chỉ env.
- Cấm production: NOTIF_WORKER_FORCE_FAIL, TEMP captcha, debug unblock không key.

14. Delayed task — Tách Turnstile thành lớp độc lập (P2/P3)

Quyết định kiến trúc (2026-07-28): ghi nhận as-is và hướng đích; không block đóng backbone W0–W5.

14.1 As-is

- Orchestration: auth.controller (login/register/forgot/verify-reset).
- I/O siteverify: turnstile.utils.
- Policy: securityConfig.TURNSTILE_REQUIRED.
- Đủ an toàn production nếu không TEMP bypass và REQUIRED=true.

14.2 Vì sao chưa phải lỗi hỏng

- Doctrine không bắt buộc file controller; bắt buộc hành vi verify server-side.
- Utils đã tách I/O; không nhúng Cloudflare vào auth.service domain.

14.3 Hướng đích (khung độc lập)

Route: ratelimit → turnstileMiddleware(action) → controller
turnstileMiddleware → turnstile.utils + securityConfig

- Không đặt bot-gate vào auth.service (định danh / lock / tenant assert).
- Controller mỏng: không còn khối if (!turnstileToken) lặp.

14.4 Điều kiện kích hoạt task

- Thêm form public cần Turnstile ngoài auth, hoặc
- Dọn auth.controller (cleanup), hoặc
- Chuẩn hóa “mọi bot-gate = middleware” trong SEC guide.

14.5 Ưu tiên & Q1 khi làm

Trường	Giá trị
Ưu tiên	P2/P3 — delayed task; không P0 an ninh đang mở
Q1	Giữ HTTP 403, message, log TURNSTILE_*, thứ tự honeypot/IP không đổi hành vi
Regression	login/register/forgot thiếu token & sai token; TURNSTILE_REQUIRED=false dev

15. Residual khác còn mở

Mục	Ghi chú
Channel notif thật	Worker stub SENT
Cron host	Jobs CLI — cần scheduler
DELEGATED_ACTION wire	Helper sẵn; chưa đủ admin path
branch_name Prisma	query-reviewable select sai field
Turnstile middleware	Mục 14 — P2/P3
Redis / Outbox table	Cố ý chưa làm

16. Kết luận

Kiến trúc SEC EGAL đã hiện thực Defense-in-Depth có pipeline rõ, cổng tenant Light/Heavy, login assert order, Turnstile cấu hình hóa (as-is controller + utils; đích middleware delayed), rate/guard, notif PENDING + SKIP LOCKED worker, BPL ủy quyền/job.

Mọi PR mới đối chiếu mục 3, 11, 14. Không phá lock Master v1.2.

Tham chiếu: Handoff-W0...W5; EGAL-SEC Doctrine v1.1; Báo cáo thực hiện Master Plan v1.2.

— Hết báo cáo chuyên đề SEC Guide v1.1 —